

PENETRATION TESTING ASSESSMENT REPORT

DVWA — Authentication Bypass (Brute Force Attack)

Prepared by:	Muhammad Adeel Tariq
Certification:	CEH (EC-Council) Certified
Training Program:	NAVTTTC-funded Cybersecurity Training, Corvit Institute, Rawalpindi
Classification:	Educational / Controlled Lab Environment

EXECUTIVE SUMMARY

This report documents a security assessment of DVWA's (Damn Vulnerable Web Application) login mechanism, performed under the Low security setting within an isolated Metasploitable 2 lab environment. The assessment identified a weak authentication control (CWE-307) allowing unrestricted brute-force login attempts, which resulted in successful credential compromise and unauthorized access to the application's admin panel.

SCOPE

Target Application:	DVWA (Damn Vulnerable Web Application)
Target Environment:	Metasploitable 2, isolated VirtualBox lab network
Attacker Host:	Kali Linux
Security Level Tested:	Low

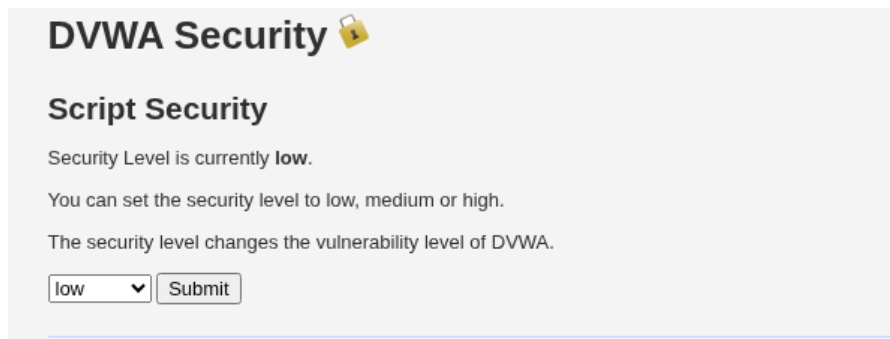
Task: Authentication Bypass Report (Brute Force Attack)

1. Objective

To identify weak authentication controls and perform a brute force attack to obtain valid login credentials.

2. Environment Setup

- Attacker Machine: Kali Linux
- Target Machine: Metasploitable 2
- Web Application: DVWA
- Security Level: Low



3. Tools Used

- Burp Suite (Proxy & Intruder)
- Kali Linux

4. Vulnerability Identified

Weak Authentication Mechanism

The application does not implement proper protections against brute force attacks, allowing unlimited login attempts.

5. Exploitation Steps

Step 1: Accessed DVWA login page

Step 2: Enabled Burp Suite and intercepted login request

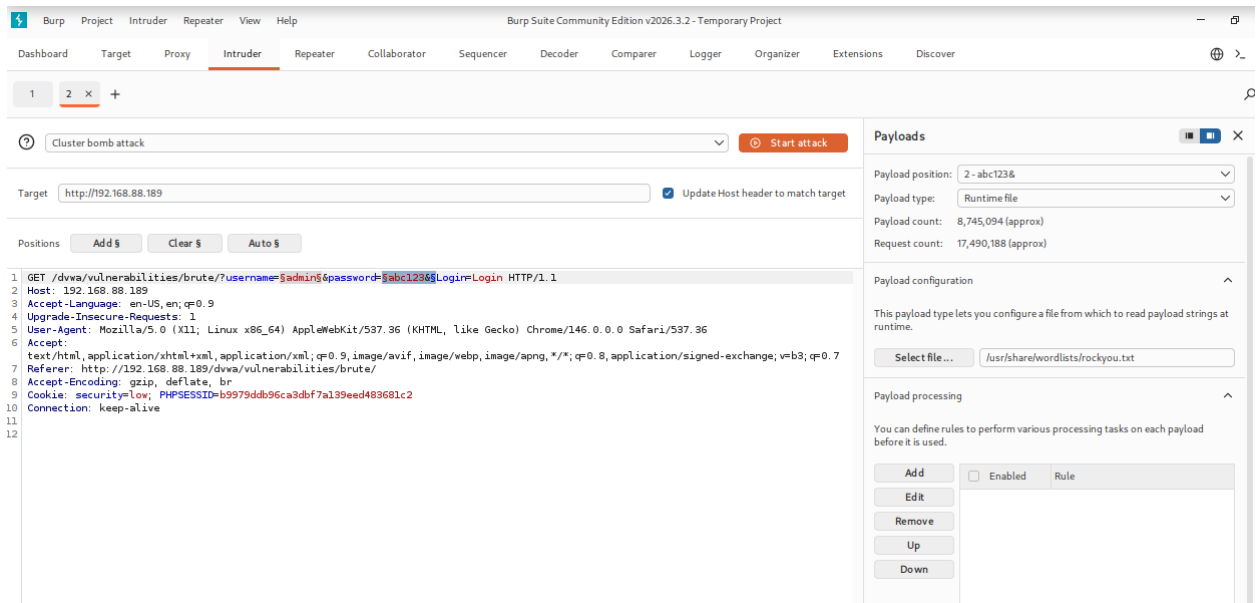
Step 3: Identified POST parameters:

- username
- password

Step 4: Sent request to Burp Intruder

Step 5: Used Cluster Bomb attack

- Username: admin (known)
- Password: Wordlist (e.g., rockyou.txt)



Step 6: Analyzed responses based on length/status

Step 7: Identified valid credentials → Login Successful

6. Result

- Successfully cracked login credentials
- Gained unauthorized access to admin panel

3. Intruder attack of http://192.168.88.85

Attack ▾

Save ▾



Results Positions

Capture filter: Capturing all items

Apply capture filter

View filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
5		123456789	200	3173			4920	
6	Admin	123456789	200	5511			4920	
7		password	200	3596			4920	
8	Admin	password	200	3309			4986	
9		iloveyou	200	3852			4920	
10	Admin	iloveyou	200	3257			4919	
11		princess	200	3530			4919	

Request Response

Pretty

Raw

Hex

Render

```
57 </h2>
58 <form action="#" method="GET">
59   Username:<br>
60   Password:<br>
61   <input type="password" AUTOCOMPLETE="off" name="password">
62   <input type="submit" value="login" name="login">
63 </form>
64 <p>
65   Welcome to the password protected area Admin
66 </p>
67 
68 </div>
```



Search



0 highlights

Selection: 44 (0x2c)

539 of 35762684

Payloads

Resource pool

Settings

7. What I Learned

Response length/status differentials in Burp Intruder are enough to detect a successful login even without visual confirmation. This reinforced why authentication endpoints need rate-limiting and lockout controls, not just strong passwords — without throttling, even a weak wordlist attack succeeds given enough time.

8. Remediation Recommendations

- Implement account lockout or exponential back-off after repeated failed login attempts
- Add a CAPTCHA or similar challenge after a threshold of failed logins
- Return uniform response length/timing for both valid and invalid login attempts
- Enforce a strong password policy to reduce wordlist-based attack success

9. Vulnerability Classification

CWE-307: Improper Restriction of Excessive Authentication Attempts